

Secure Academic Infrastructure

Enterprise Security Governance & Operations Simulation for XYZ Academy

Cybersecurity Governance • Risk Management • Incident
Response • Business Continuity

Prepared by
Saad Almutairi

Imam Mohammad Ibn Saud Islamic University
Cybersecurity Diploma

May 2026

Section 1: Introduction

Project Overview

Secure Academic Infrastructure is a cybersecurity governance and security operations simulation project designed for a medium-sized academic institution known as XYZ Academy.

The project demonstrates how organizational cybersecurity practices can be applied to protect academic systems, institutional data, and operational services within an educational environment.

XYZ Academy relies on multiple digital services, including Learning Management Systems (LMS), academic record systems, internal communication platforms, cloud backup services, administrative systems, and wireless network services.

The project focuses on improving organizational cybersecurity readiness through governance practices, risk management activities, identity protection, incident response planning, and business continuity strategies.

Academic Project Development

This project was originally developed as part of the Information Security Fundamentals course during the Cybersecurity Diploma program at Imam Mohammad Ibn Saud Islamic University.

The original academic project was later expanded and professionally redesigned into a structured cybersecurity governance and operations simulation to improve

documentation quality, organizational realism, and portfolio presentation.

The redevelopment process focused on transforming theoretical security concepts into a practical cybersecurity case study suitable for professional GitHub portfolio presentation.

Project Objectives

The primary objectives of the project include:

- Improving organizational cybersecurity governance
- Protecting academic and administrative systems
- Supporting secure identity and access management
- Reducing operational cybersecurity risks
- Improving incident response readiness
- Supporting business continuity and disaster recovery
- Enhancing cybersecurity awareness practices

Organizational Environment

XYZ Academy represents a medium-sized educational institution with the following environment characteristics:

Category	Details
Students	500–800
Staff Members	40–70
IT Team	Internal IT & Security Operations Team
Core Services	LMS, Email, Academic Records, Cloud Backup
Security Maturity	Intermediate

The environment was designed to simulate realistic operational and cybersecurity challenges commonly affecting educational institutions.

Threat Landscape

The project environment addresses several common cybersecurity threats affecting academic organizations, including:

- Phishing attacks
- Ransomware infections
- Credential theft
- Malware outbreaks
- Insider misuse
- Unauthorized access attempts
- Service disruptions

These threats may impact the confidentiality, integrity, and availability (CIA) of organizational systems and data.

Section 2: Security Governance

Governance Overview

XYZ Academy applies a structured cybersecurity governance model to establish accountability, define security responsibilities, and support the protection of academic and administrative systems.

The governance structure helps ensure that cybersecurity practices align with organizational objectives, operational requirements, and institutional security policies.

Governance Objectives

The governance program focuses on:

- Protecting organizational assets
- Supporting operational continuity
- Reducing cybersecurity risks
- Enforcing security policies
- Improving accountability
- Supporting incident response readiness

Governance Structure

The academy applies a role-based governance structure to support operational security responsibilities.

Role	Responsibilities
Management	Approve policies and support security initiatives
IT Administrators	Maintain systems, backups, and monitoring activities
Academic Staff	Protect academic systems and report suspicious activities
Students	Follow acceptable use policies and security guidelines
Security Operations Personnel	Monitor events and support incident handling

Core Governance Principles

The project governance model applies several security principles:

- Least Privilege
- Role-Based Access Control (RBAC)
- Separation of Duties (SoD)
- Accountability
- Security Awareness
- Continuous Monitoring

These principles help reduce unauthorized access and improve operational security management.

Security Policy Framework

XYZ Academy applies organizational security policies to regulate system usage and reduce security risks.

Included policies include:

- Acceptable Use Policy (AUP)
- Password Security Policy
- Access Control Policy
- Incident Reporting Policy
- Backup & Recovery Policy

These policies help improve institutional cybersecurity maturity and support consistent security practices across the environment.

Security Awareness

Security awareness activities are used to improve user understanding of cybersecurity risks and responsible system usage.

Awareness topics include:

- Phishing awareness
- Password protection
- Safe email usage
- Responsible internet usage
- Reporting suspicious activities

Continuous awareness activities help strengthen organizational security culture.

Governance Importance

Effective security governance improves organizational coordination, supports risk management activities, and helps maintain the confidentiality, integrity, and availability (CIA) of institutional systems and data.

Section 3: Risk Management

Risk Management Overview

XYZ Academy applies a structured risk management approach to identify, evaluate, and reduce cybersecurity risks affecting academic systems, organizational operations, and institutional data.

The risk management process focuses on protecting critical assets while supporting operational continuity and organizational resilience.

Risk Management Objectives

The program aims to:

- Identify critical organizational assets
- Evaluate potential cybersecurity threats
- Assess operational impact
- Reduce vulnerability exposure
- Support incident readiness
- Improve organizational resilience

Asset Classification

Organizational assets were categorized based on operational importance and business impact.

Asset Category	Examples	Criticality
Academic Data	Student records, grades, attendance	High
Learning Systems	LMS platform, academic portals	High
Communication Services	Email systems, staff communication	Medium
End-User Devices	Staff laptops, student workstations	Medium
Cloud Services	Cloud backup platforms	High
Network Infrastructure	Routers, switches, wireless access points	High

Risk Assessment Criteria

Risks were evaluated using multiple factors:

Factor	Description
Threat Likelihood	Probability of threat occurrence
Business Impact	Potential operational damage
Asset Criticality	Importance of affected systems
Vulnerability Exposure	Weaknesses exploitable by attackers

Risk levels were categorized as:

- Low
- Medium
- High
- Critical

High-Priority Risks

Risk	Potential Impact	Mitigation Strategy
Phishing Attacks	Credential compromise	MFA + awareness training
Ransomware	Loss of academic services	Offline backups + endpoint protection
Weak Passwords	Unauthorized access	Strong password policy
Insider Misuse	Exposure of sensitive information	RBAC enforcement
Malware Infections	Device compromise	Antivirus & monitoring controls
Service Outages	LMS disruption	Backup recovery procedures

Risk Mitigation Strategy

The organization applies layered security controls to reduce operational risks.

Implemented controls include:

- Security awareness training
- Multi-factor authentication (MFA)
- Access control enforcement
- Endpoint protection
- Backup & recovery procedures
- Continuous monitoring
- Incident escalation workflows

These controls improve operational resilience while supporting secure academic operations.

Organizational Impact

Effective risk management improves the protection of academic systems, reduces operational disruption, and supports the confidentiality, integrity, and availability (CIA) of institutional information assets.

Section 4: IAM (Identity and Access Management)

IAM Overview

XYZ Academy applies Identity and Access Management (IAM) practices to ensure that users can only access systems and resources required for their operational responsibilities.

The IAM framework helps reduce unauthorized access, improve accountability, and support organizational security operations.

User Categories

The simulated environment includes multiple user groups with different access requirements.

User Type	Access Scope
Students	LMS access, academic materials, personal records
Teachers	Course management, grading systems, communication services
Administrative Staff	Academic records and administrative systems
IT Administrators	Infrastructure management, backups, and monitoring systems
Security Operations Personnel	Security monitoring and incident handling activities

Access Control Principles

The academy environment applies multiple access control principles:

- Least Privilege
- Role-Based Access Control (RBAC)

- Separation of Duties (SoD)
- Need-to-Know Access
- Centralized Identity Management

These principles help limit excessive permissions and reduce operational security risks.

Authentication Security

Authentication controls are implemented to improve account protection and reduce unauthorized access attempts.

Implemented controls include:

- Unique user accounts
- Strong password requirements
- Multi-factor authentication (MFA) for privileged accounts
- Password expiration policies
- Account lockout mechanisms after repeated failed login attempts

Privileged administrative systems require stronger authentication protections due to their higher operational sensitivity.

Authorization Management

Authorization processes determine what resources each authenticated user can access within the environment.

Examples include:

- Students can access academic content but cannot modify records.
- Teachers can manage course materials and grading systems.
- Administrative staff can access reporting systems.
- IT administrators maintain infrastructure and backup services.

Authorization is controlled according to operational responsibilities and security policies.

Account Lifecycle Management

User accounts follow a structured lifecycle management process.

Account Provisioning

- New accounts are created according to user roles.
- Access approval is performed by authorized personnel.

Access Modification

- Permissions are adjusted when responsibilities or departments change.

Account Deactivation

- Accounts are disabled after graduation, resignation, or termination.

This process reduces the risk of orphaned accounts and unauthorized persistent access.

Accountability and Monitoring

Authentication and access activities are logged and monitored to improve accountability and support incident investigations.

Examples include:

- Failed login attempts
- Administrative actions
- Password reset activities
- Access to sensitive systems
- Privileged account usage

Monitoring access activities supports operational security visibility and incident response readiness.

Section 5: Security Operations and Monitoring

Monitoring Overview

XYZ Academy applies operational security monitoring activities to improve visibility into system events, user activities, and security-related incidents.

Monitoring activities support early threat detection, operational awareness, and incident response readiness across the academic environment.

Monitoring Objectives

The monitoring process focuses on:

- Detecting suspicious activities
- Improving operational visibility
- Supporting incident investigations
- Monitoring authentication events
- Identifying abnormal behavior
- Supporting organizational accountability

Security Monitoring Activities

The project environment includes several monitoring activities designed to improve operational security awareness.

Examples include:

- Monitoring failed login attempts

- Reviewing authentication activities
- Monitoring administrative actions
- Detecting unusual account behavior
- Monitoring service interruptions
- Reviewing backup operation status

These activities help improve visibility into organizational security events.

Intrusion Detection Concepts

The environment applies monitoring concepts aligned with IDPS principles.

Monitoring activities focus on identifying:

- Unauthorized access attempts
- Malware-related behavior
- Repeated failed authentication attempts
- Suspicious account activities
- Abnormal network communication

Security alerts are reviewed by IT and security personnel for further investigation.

Logging and Event Management

Critical systems generate logs to support accountability and operational investigations.

Logged activities include:

- User authentication events
- Administrative activities
- Password reset operations
- Access control events
- System error events
- Backup operations

Centralized log collection improves operational visibility and incident tracking.

Security Alert Handling Workflow

When suspicious activity is detected:

1. The event is identified and reviewed.
2. The affected system or account is verified.
3. IT personnel assess the severity of the event.
4. Containment actions are applied if required.
5. Recovery procedures are initiated.
6. The incident is documented for future review.

This workflow improves operational coordination and incident readiness.

Operational Security Awareness

Monitoring operations are supported by continuous security awareness activities.

Users are encouraged to:

- Report suspicious emails
- Avoid unknown attachments
- Protect account credentials
- Follow organizational security policies
- Report unusual system behavior immediately

User participation improves operational security effectiveness and reduces cybersecurity risks.

Section 6: Incident Response

Incident Response Overview

XYZ Academy applies structured incident response procedures to minimize the impact of cybersecurity incidents and restore normal operations efficiently.

The response process focuses on identifying incidents, containing affected systems, recovering services, and improving future security readiness.

Common Threat Scenarios

The project environment includes several realistic cybersecurity threats commonly targeting educational institutions.

Simulated threats include:

- Phishing attacks
- Ransomware infections
- Malware outbreaks
- Unauthorized access attempts
- Credential misuse
- Service disruptions

These scenarios were analyzed to improve organizational preparedness and response coordination.

Phishing Incident Scenario

Attack Description

A staff member receives an email claiming to be from the academy IT department requesting urgent password verification.

The email contains a fake login page designed to capture user credentials.

Believing the message is legitimate, the user attempts to log in through the malicious website.

Potential Impact

A successful phishing attack may result in:

- Compromised user accounts
- Unauthorized access to academic systems
- Exposure of student records
- Internal phishing propagation
- Loss of organizational trust

Detection Indicators

Possible phishing indicators include:

- Suspicious email addresses
- Unexpected password requests
- Fake login pages
- Urgent or threatening language

- Unknown links or attachments

Users are encouraged to report suspicious emails immediately.

Incident Response Process

Phase	Response Activity
Detection	Suspicious email reported by user
Verification	IT team reviews email legitimacy
Containment	Affected account temporarily disabled
Investigation	Authentication logs reviewed
Recovery	Password reset and MFA verification
Awareness	Staff informed about phishing indicators

Ransomware Incident Scenario

Attack Description

A malicious attachment disguised as an academic document is opened on a staff device, triggering ransomware execution.

The malware executes and begins encrypting local files and shared academic resources connected to the device.

The affected systems display ransom messages requesting payment in exchange for file decryption.

Potential Impact

A successful ransomware attack may result in:

- Loss of access to academic records
- LMS service disruption

- Encryption of institutional files
- Operational downtime
- Delayed academic activities

Detection Indicators

Possible ransomware indicators include:

- Unusual file encryption activity
- Inaccessible documents
- Unexpected ransom messages
- Abnormal system performance
- Sudden file extension changes

Rapid detection helps reduce the spread of ransomware across organizational systems.

Incident Response Process

Phase	Response Activity
Detection	Suspicious encryption activity identified
Containment	Infected device isolated from network
Investigation	Malware source analyzed
Recovery	Backup restoration procedures initiated
Validation	Restored systems verified
Documentation	Incident reviewed and recorded

Incident Documentation

All major security incidents should be documented to support:

- Future investigations
- Security improvements
- Risk assessment updates
- Awareness activities
- Operational accountability

Incident records improve organizational learning and strengthen future response capabilities.

Section 7: Business Continuity and Disaster Recovery

Continuity and Recovery Overview

XYZ Academy applies Business Continuity Planning (BCP) and Disaster Recovery Planning (DRP) principles to maintain critical academic operations during cybersecurity incidents, technical failures, or service disruptions.

The continuity strategy focuses on minimizing downtime, protecting academic data, and restoring critical services efficiently.

Continuity Objectives

The continuity and recovery process aims to:

- Maintain critical academic operations
- Reduce service disruption
- Protect institutional information assets
- Support recovery coordination
- Improve organizational resilience
- Maintain service availability

Critical Services

The following services were identified as operationally critical within the academy environment.

Service	Importance
LMS (Learning Management System)	High
Academic Records System	High
Staff Communication Services	High
Administrative Systems	High
Cloud Backup Services	High
Internet Connectivity	Medium

Recovery Objectives

The project environment applies recovery objectives to support operational continuity.

Objective	Description
RTO (Recovery Time Objective)	Maximum acceptable downtime before services are restored
RPO (Recovery Point Objective)	Maximum acceptable amount of data loss during disruption

Defined recovery targets include:

- RTO: 4–6 hours
- RPO: 24 hours

Backup Strategy

The organization applies multiple backup methods to improve recovery readiness.

Backup methods include:

- Daily automated backups

- Weekly full-system backups
- Cloud-based backup storage
- Offline backup storage for critical data

Backup integrity should be verified regularly to ensure recovery reliability.

Disaster Recovery Workflow

When a major disruption occurs:

1. The incident is identified and assessed.
2. Affected systems are isolated if necessary.
3. Backup restoration procedures are initiated.
4. Critical systems are restored based on recovery priorities.
5. Restored systems are tested and validated.
6. Users are informed about service restoration.
7. The incident is documented for future improvement.

Continuity Support Measures

To reduce operational disruption during incidents, the organization applies several continuity support measures.

Examples include:

- Alternative communication methods
- Temporary offline teaching resources
- Manual administrative procedures

- Priority restoration for critical systems
- Backup access procedures

These measures help maintain essential academic functions during service interruptions.

Organizational Resilience

Effective business continuity and disaster recovery planning improve organizational resilience by reducing downtime, supporting operational continuity, and improving preparedness during cybersecurity incidents and infrastructure failures.

Section 8: Conclusion

Project Summary

Secure Academic Infrastructure is a cybersecurity governance and security operations simulation project developed to demonstrate how fundamental cybersecurity concepts can be applied within a realistic academic environment.

The project focused on protecting organizational systems, improving operational security practices, supporting risk management activities, and strengthening incident response and recovery readiness.

Implemented Security Areas

The project included multiple cybersecurity domains, including:

- Security Governance
- Risk Management
- Identity and Access Management (IAM)
- Security Operations and Monitoring
- Incident Response
- Business Continuity Planning (BCP)
- Disaster Recovery Planning (DRP)
- Security Awareness and Organizational Policies

These areas were integrated to simulate a structured institutional cybersecurity environment.

Organizational Security Improvements

The project environment applied several security practices to improve organizational protection and operational resilience.

Examples include:

- Role-Based Access Control (RBAC)
- Multi-factor authentication (MFA)
- Security monitoring activities
- Backup and recovery procedures
- Security awareness initiatives
- Incident escalation workflows
- Access control enforcement

These measures help support the confidentiality, integrity, and availability (CIA) of institutional systems and information assets.

Academic and Professional Development

The project originally began as an academic activity within the Information Security Fundamentals course and was later expanded into a professionally organized cybersecurity documentation project.

The redevelopment process helped improve understanding of cybersecurity governance concepts, operational security planning, organizational risk management, and security documentation practices.

The project also provided practical experience in structuring cybersecurity documentation and presenting security concepts in a professional portfolio-oriented format.

Final Statement

Cybersecurity governance and operational readiness play a critical role in protecting modern educational institutions from evolving digital threats.

By combining governance principles, risk management strategies, monitoring activities, incident response procedures, and continuity planning, organizations can improve resilience and maintain secure academic operations in increasingly connected environments.